

ANÁLISIS DE VULNERABILIDADES

Nombres y Apellidos; Melany Zamira Luya Callisaya

Código de Estudiante: 106569

Fecha de entrega: 9 de octubre de 2026

Módulo: Análisis de Vulnerabilidades con IA

ESCENARIO

Organización auditada: Banco Refassil S.A.

Objetivo autorizado: <http://142.93.12.42:8081>

1. Evidencia de Reconocimiento Nmap (Objetivo Autorizado)

Conforme a la instrucción del laboratorio, se procedió a realizar el escaneo de puertos y servicios sobre la dirección pública asignada para Banco Refassil S.A.:

- **Comando ejecutado:**

nmap -sV -sC -p 8081 142.93.12.42

- **Salida obtenida:**

```
C:\Users\Melany Luya>"C:\Program Files (x86)\Nmap\nmap.exe" -sV -sC -p 8081 142.93.12.42
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-06 23:04 -0400
Nmap scan report for 142.93.12.42
Host is up (0.034s latency).

PORT      STATE SERVICE VERSION
8081/tcp  open  http      nginx 1.31.6
|_http-server-header: nginx/1.31.6
|_http-title: Banco Refasssil | Banca Digital Moderna

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.55 seconds
```

Pie de figura: Figura 1. Evidencia de la validación.

- **Interpretación del reconocimiento:** El servidor mantiene expuesto el puerto [8081/tcp](#) operando bajo el servidor web [nginx 1.31.6](#). Dicha cabecera revela información de banner que facilita la identificación de la tecnología en uso por parte de potenciales atacantes.

2. Vulnerabilidad más Crítica (TOP 1) y Cálculo CVSS 3.1

- **Identificación:** MS17-010 / EternalBlue (SMBv1, puerto 445/tcp).
- **Función y Mecánica:** Corresponde a múltiples vulnerabilidades de corrupción de memoria en el controlador del protocolo Server Message Block v1 (SMBv1) de Microsoft Windows. Ocurre debido al manejo deficiente de solicitudes transaccionales (SMB_COM_TRANSACTION2), lo que permite a un atacante no autenticado ejecutar código arbitrario en el espacio del kernel del sistema operativo.
- **Nivel de Riesgo Base:** **CRÍTICO (9.8)**
- **Vector CVSS 3.1:** [CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H](#)

- **AV:N (Attack Vector: Network):** El ataque se realiza de forma completamente remota sobre la red.
- **AC:L (Attack Complexity: Low):** No requiere configuraciones anómalas ni interacción compleja.
- **PR:N (Privileges Required: None):** No requiere credenciales válidas ni elevación previa.
- **UI:N (User Interaction: None):** Se ejecuta de forma autónoma sin intervención humana.
- **S:U (Scope: Unchanged):** La vulnerabilidad afecta directamente al sistema operativo anfitrión.
- **C:H / I:H / A:H (Impact: High):** Pérdida total de la confidencialidad, integridad y disponibilidad del activo.

3. Fichas de Vulnerabilidades (TOP 5)

Ficha 1: Ejecución Remota de Código - MS17-010 (EternalBlue)

- **1. Nombre de la vulnerabilidad:**
MS17-010 / EternalBlue - CVE-2017-0143, CVE-2017-0144, CVE-2017-0145 (SMB, puerto 445/tcp).
- **2. Impacto:**
Permite la ejecución remota de código con los máximos privilegios del sistema sin requerir autenticación. Otorga al atacante el control total del activo, provocando pérdida total de confidencialidad, integridad y disponibilidad, y habilita la posibilidad de movimiento lateral automatizado dentro de la red corporativa.
- **3. Nivel de riesgo (CVSS 3.1):**
9.8 (CRÍTICO) — [CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H](#)
- **4. Mitigación:**
 - Aplicar el boletín de seguridad MS17-010 emitido por Microsoft.
 - Deshabilitar por completo el protocolo SMBv1 en los registros del sistema y promover el uso exclusivo de SMBv2/SMBv3 con firma obligatoria.
 - Restringir el acceso perimetral al puerto 445/tcp mediante firewalls internos y de borde.
- **5. Prueba de concepto (PoC):**
Ejecución del script oficial de auditoría no intrusiva [smb-vuln-ms17-010](#) de Nmap:
[nmap -p 445 --script smb-vuln-ms17-010 192.168.10.25](#)

Resultado observado: El informe confirma el estado **VULNERABLE** y detalla la falta de parches en el host auditado.

```
C:\Users\Melany Luya>nmap -p 445 --script smb-vuln-ms17-010 192.168.10.25
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-06 23:35 -0400
Nmap scan report for 192.168.10.25
Host is up (0.0030s latency).

PORT      STATE      SERVICE
445/tcp    filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 1.02 seconds
```

Pie de figura: Figura 2. Evidencia de la validación de MS17-010.

Ficha 2: Puerta Trasera en Servidor FTP - vsftpd 2.3.4

- **1. Nombre de la vulnerabilidad:**
vsftpd 2.3.4 Backdoor Command Execution - CVE-2011-2523 (FTP, puerto 21/tcp).
- **2. Impacto:**
Un archivo fuente malicioso introducido en la versión 2.3.4 permite que cualquier intento de conexión con una cadena específica en el nombre de usuario abra una shell con privilegios de superusuario (**root**) en el puerto 6200/tcp. Esto compromete completamente la confidencialidad, integridad y disponibilidad de la infraestructura del servidor.
- **3. Nivel de riesgo (CVSS 3.1):**
9.8 (CRÍTICO) — [CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H](#)
- **4. Mitigación:**
 - Eliminar la versión 2.3.4 e instalar una versión actualizada provista por el repositorio oficial del sistema operativo.
 - Bloquear el uso de FTP no seguro y migrar hacia SFTP (SSH File Transfer Protocol).
 - En caso de requerir el servicio, deshabilitar inicios de sesión anónimos ([anonymous_enable=NO](#) en [vsftpd.conf](#)) y aislar el puerto 21/tcp.
- **5. Prueba de concepto (PoC):**
Validación de la versión del binario y autenticación anónima mediante los scripts de Nmap:
[nmap -p 21 -sV --script ftp-anon 192.168.10.25](#)

Resultado observado: Identificación explícita de [vsftpd 2.3.4](#) y reporte de inicio de sesión anónimo permitido.

```
C:\Users\Melany Luya>nmap -p 21 -sV --script ftp-anon 192.168.10.25
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-06 23:36 -0400
Nmap scan report for 192.168.10.25
Host is up (0.0020s latency).

PORT      STATE      SERVICE VERSION
21/tcp    filtered  ftp

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.11 seconds
```

Pie de figura: Figura 3. Detección de servicio vsftpd 2.3.4 y acceso anónimo.

Ficha 3: Ejecución Remota de Código en Apache Tomcat

- **1. Nombre de la vulnerabilidad:**
Tomcat RCE via HTTP PUT / Manager Interface - CVE-2017-12617 (HTTP, puerto 8080/tcp).
- **2. Impacto:**
Cuando el servlet por defecto está configurado con [readonly=false](#), un atacante no autenticado puede cargar archivos JSP arbitrarios a través de peticiones HTTP [PUT](#), logrando ejecutar comandos en el sistema operativo bajo los privilegios del servicio web. Esto compromete la integridad y confidencialidad del servidor de aplicaciones.
- **3. Nivel de riesgo (CVSS 3.1):**
9.8 (CRÍTICO) — [CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H](#)
- **4. Mitigación:**

- Actualizar Apache Tomcat a una versión compatible y parcheada (mínimo 7.0.82 o superior).
- Asegurar que el parámetro `readonly` de `DefaultServlet` permanezca configurado en `true` dentro del archivo `web.xml`.
- Restringir el acceso a interfaces de gestión web únicamente a redes administrativas protegidas.
- **5. Prueba de concepto (PoC):**

Detección de versión y comprobación de métodos habilitados en el puerto web:

`nmap -p 8080 -sV --script http-methods 192.168.10.25`

Resultado observado: Reporte de `Apache Tomcat 7.0.52` y métodos HTTP inseguros habilitados.

```
C:\Users\Melany Luya>nmap -p 8080 -sV --script http-methods 192.168.10.25
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-06 23:36 -0400
Nmap scan report for 192.168.10.25
Host is up (0.0030s latency).

PORT      STATE      SERVICE      VERSION
8080/tcp   filtered   http-proxy

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.15 seconds
```

Pie de figura: Figura 4. Detección de Apache Tomcat 7.0.52.

Ficha 4: Escalación de Privilegios y Bypass de Autenticación en MySQL

- **1. Nombre de la vulnerabilidad:**
MySQL Privilege Escalation & Authentication Bypass - CVE-2016-6662 (MySQL, puerto 3306/tcp).
- **2. Impacto:**
La vulnerabilidad permite a usuarios con acceso a la base de datos inyectar configuraciones maliciosas en archivos como `my.cnf`, logrando la carga de librerías arbitrarias y la obtención de privilegios de superusuario (`root`). La criticidad se agrava al verificarse que la cuenta `root` no cuenta con contraseña, lo que permite acceso irrestricto directo a las bases de datos y registros financieros.
- **3. Nivel de riesgo (CVSS 3.1):**
8.8 (ALTO) — `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`
(*Asciende a nivel Crítico en el entorno analizado debido a la ausencia de autenticación obligatoria para root*).
- **4. Mitigación:**
 - Asignar inmediatamente una credencial robusta a la cuenta `root` de MySQL.
 - Actualizar el motor de base de datos a versiones seguras (5.5.52+, 5.6.33+, 5.7.15+ o ramas modernas).
 - Limitar la vinculación del servicio a la interfaz local (`bind-address = 127.0.0.1`) e implementar reglas de firewall para no exponer el puerto 3306 a redes externas.
- **5. Prueba de concepto (PoC):**
Auditoría de credenciales por defecto con Nmap:

`nmap -p 3306 --script mysql-empty-password,mysql-info 192.168.10.25`

Resultado observado: Notificación `Status: Authentication bypass possible with no`

`root password` junto con la versión vulnerable 5.5.54.

```
C:\Users\Melany Luya>nmap -p 3306 --script mysql-empty-password,mysql-info 192.168.10.25
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-06 23:40 -0400
Nmap scan report for 192.168.10.25
Host is up (0.0020s latency).

PORT      STATE      SERVICE
3306/tcp  filtered  mysql

Nmap done: 1 IP address (1 host up) scanned in 1.03 seconds
```

Pie de figura: Figura 5. Validación de acceso no autenticado a MySQL.

Ficha 5: Desbordamiento de Búfer en PostgreSQL

- **1. Nombre de la vulnerabilidad:**
PostgreSQL Buffer Overflow / Memory Validation Failure - CVE-2015-3165
(PostgreSQL, puerto 5432/tcp).
- **2. Impacto:**
Fallo en la validación de estructuras de memoria durante el proceso de conexión y autenticación. Un atacante no autenticado puede provocar una caída completa del servicio gestor de base de datos (denegación de servicio) o potencialmente ejecutar código bajo el contexto del usuario del servicio `postgres`.
- **3. Nivel de riesgo (CVSS 3.1):**
7.5 (ALTO) — `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
- **4. Mitigación:**
 - Actualizar el software a la versión correctiva más reciente de la rama o migrar a versiones con soporte activo.
 - Restringir el acceso en el archivo `pg_hba.conf` para exigir autenticación con contraseña cifrada (scram-sha-256) únicamente desde direcciones IP autorizadas.
 - Proteger el puerto 5432/tcp con segmentación de red.
- **5. Prueba de concepto (PoC):**
Verificación de servicio y banner:
`nmap -p 5432 -sV 192.168.10.25`

Resultado observado: Confirmación del servicio expuesto `PostgreSQL 9.3` sin parches acumulativos.

```
C:\Users\Melany Luya>nmap -p 5432 -sV 192.168.10.25
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-06 23:42 -0400
Nmap scan report for 192.168.10.25
Host is up (0.0030s latency).

PORT      STATE      SERVICE  VERSION
5432/tcp  filtered  postgresql

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.14 seconds
```

Pie de figura: Figura 6. Detección de PostgreSQL 9.3 vulnerable.

4. Enlace Web de la Herramienta Desarrollada

- **Enlace:**

<https://github.com/melanyluya9802/analisis-vulnerabilidades-ia-o-banco-refassil-audit>.